

Security+ 1.4 · Blockchain Technology

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 1.4 — Blockchain Technology**
(2:22) · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Blockchain: ledger público distribuído; cada bloco contém hash do anterior — cadeia tamper-evident. Public (Bitcoin — open) vs Private blockchain (permissão controlada). Smart contracts = código executando em cima do ledger.

Highlights que a prova cobra

- Cada bloco contém o hash do ANTERIOR — mudou um, quebrou a cadeia
- Public (Bitcoin — open) vs Private (permissão restricta)

Dicas de prova & Cenários Típicos

- 'tamper-evident distributed ledger' = blockchain
- 'each block contains a hash of the previous' = prova de encadeamento

Cenário clássico de exame: Cenário: 'empresa quer garantir que os logs não podem ser alterados retroativamente' — blockchain (tamper-evident).

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 1.4 — Blockchain Technology)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Uma característica de HASH (diferente de criptografia) é que ele:

- A)** Pode ser revertido com a chave
- B)** É de mão única (não reversível)
- C)** Sempre encurta o texto pela metade
- D)** Precisa de par de chaves

2. Qual função criptográfica NÃO é reversível?

- A)** Criptografia AES
- B)** Criptografia RSA
- C)** Hash SHA-256
- D)** Codificação Base64

3. Cenário corporativo (Blockchain Technology): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Cada bloco contém o hash do ANTERIOR — mudou um, quebrou a cadeia'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cada bloco contém o hash do ANTERIOR — mudou um, quebrou a cadeia...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Blockchain Technology): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Public (Bitcoin — open) vs Private (permissão restrita)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Public (Bitcoin — open) vs Private (permissão restrita)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Blockchain Technology): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'tamper-evident distributed ledger' = blockchain'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'tamper-evident distributed ledger' = blockchain...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Blockchain Technology): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'each block contains a hash of the previous' = prova de encadeamento'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'each block contains a hash of the previous' = prova de encadeamento...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Blockchain Technology): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'empresa quer garantir que os logs não podem ser alterados retroativamente' — blockchain (tamper-evident)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário: 'empresa quer garantir que os logs não podem ser alterados retroat...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Blockchain Technology): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Cada bloco contém o hash do ANTERIOR — mudou um, quebrou a cadeia'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cada bloco contém o hash do ANTERIOR — mudou um, quebrou a cadeia...

9. Cenário corporativo (Blockchain Technology): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Public (Bitcoin — open) vs Private (permissão restricta)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Public (Bitcoin — open) vs Private (permissão restricta)...

10. Cenário corporativo (Blockchain Technology): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'tamper-evident distributed ledger' = blockchain'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'tamper-evident distributed ledger' = blockchain...

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — É de mão única (não reversível).

✓ **Por que está certa:** Uma característica fundamental das funções hash criptográficas é serem de mão única (one-way), ou seja, não reversíveis. Isso significa que, a partir do hash, não é possível recuperar a mensagem original. Essa propriedade é conhecida como resistência à pré-imagem. Diferentemente da criptografia, que é reversível com a chave correta, o hash é projetado para ser irreversível. O CompTIA Security+ destaca que funções hash como SHA-256 são usadas para integridade e armazenamento de senhas (com salt), justamente porque não podem ser revertidas. A opção 'É de mão única (não reversível)' descreve corretamente essa característica essencial.

✗ **Por que as outras estão erradas:**

- *Pode ser revertido com a chave:* Essa é uma característica da criptografia simétrica ou assimétrica, não de funções hash. Na criptografia, a reversão é possível com a chave apropriada (simétrica) ou com a chave privada (assimétrica). Funções hash não possuem chave e não são projetadas para reversão. Portanto, essa afirmação está incorreta para hash. O CompTIA Security+ enfatiza que hash é unidirecional e não usa chaves, ao contrário da cifra.
- *Sempre encurta o texto pela metade:* Funções hash produzem uma saída de tamanho fixo, independentemente do tamanho da entrada. Por exemplo, SHA-256 sempre gera 256 bits (32 bytes). Não há uma regra de 'encurtar pela metade'; o tamanho do digest é constante e definido pelo algoritmo. Além disso, a função hash não é uma compressão simples; ela deve ser resistente a colisões e pré-imagem. Essa afirmação é tecnicamente falsa e não descreve uma propriedade de hash.
- *Precisa de par de chaves:* Funções hash não utilizam chaves. Elas são algoritmos públicos e determinísticos que mapeiam dados de entrada para um resumo. O uso de par de chaves é característico de criptografia assimétrica (como RSA ou ECC), não de hash. Embora hashes possam ser usados em conjunto com chaves em HMAC, a função hash em si não requer chaves. Portanto, essa opção está incorreta.

2) C — Hash SHA-256.

✓ **Por que está certa:** A alternativa correta é 'Hash SHA-256'. Funções de hash criptográfico, como SHA-256, são projetadas para serem unidirecionais (não reversíveis). Elas produzem um resumo de tamanho fixo (256 bits no caso do SHA-256) a partir de uma entrada de qualquer tamanho. Não existe uma chave secreta e não há forma prática de reverter o hash para obter a mensagem original, exceto por ataques de força bruta ou tabelas pré-computadas, que são inviáveis para entradas complexas. A CompTIA Security+ enfatiza que hashing garante integridade, não confidencialidade, e é irreversível por design.

✗ **Por que as outras estão erradas:**

- *Criptografia AES:* AES (Advanced Encryption Standard) é um algoritmo de criptografia simétrica reversível. Com a chave correta, o texto cifrado pode ser decifrado de volta ao texto claro. Portanto, é incorreto afirmar que AES não é reversível; sua reversibilidade é uma característica fundamental para a confidencialidade.
- *Criptografia RSA:* RSA é um algoritmo de criptografia assimétrica reversível. A chave privada permite decifrar o que foi cifrado com a chave pública (e vice-versa para assinaturas). Assim, RSA é reversível por natureza, desde que a chave apropriada seja conhecida. A alternativa é incorreta porque confunde criptografia com hashing.
- *Codificação Base64:* Base64 é uma codificação de dados que representa binário em texto ASCII usando 64 caracteres. Não é criptografia e é totalmente reversível (decodificação). Não oferece

segurança alguma, apenas facilita transporte. A alternativa é incorreta porque Base64 não é uma função criptográfica e é trivialmente reversível.

3) C — Implementar a solução correspondente: Cada bloco contém o hash do ANTERIOR — mudou um, quebrou a cadeia....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Blockchain Technology): Cada bloco contém o hash do ANTERIOR — mudou um, quebrou a cadeia.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) A — Implementar a solução correspondente: Public (Bitcoin — open) vs Private (permissão restricta)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Blockchain Technology): Public (Bitcoin — open) vs Private (permissão restricta).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) B — Implementar a solução correspondente: 'tamper-evident distributed ledger' = blockchain....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Blockchain Technology): 'tamper-evident distributed ledger' = blockchain.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) C — Implementar a solução correspondente: 'each block contains a hash of the previous' = prova de encadeamento....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Blockchain Technology): 'each block contains a hash of the previous' = prova de encadeamento.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) C — Implementar a solução correspondente: Cenário: 'empresa quer garantir que os logs não podem ser alterados retroat....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Blockchain Technology): Cenário: 'empresa quer garantir que os logs não podem ser alterados retroativamente' — blockchain (tamper-evident)..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) D — Implementar a solução correspondente: Cada bloco contém o hash do ANTERIOR — mudou um, quebrou a cadeia....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Blockchain Technology): Cada bloco contém o hash do ANTERIOR — mudou um, quebrou a cadeia.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) D — Implementar a solução correspondente: Public (Bitcoin — open) vs Private (permissão restricta)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Blockchain Technology): Public (Bitcoin — open) vs Private (permissão restricta).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: 'tamper-evident distributed ledger' = blockchain....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Blockchain Technology): 'tamper-evident distributed ledger' = blockchain.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.